

CATIS Framework

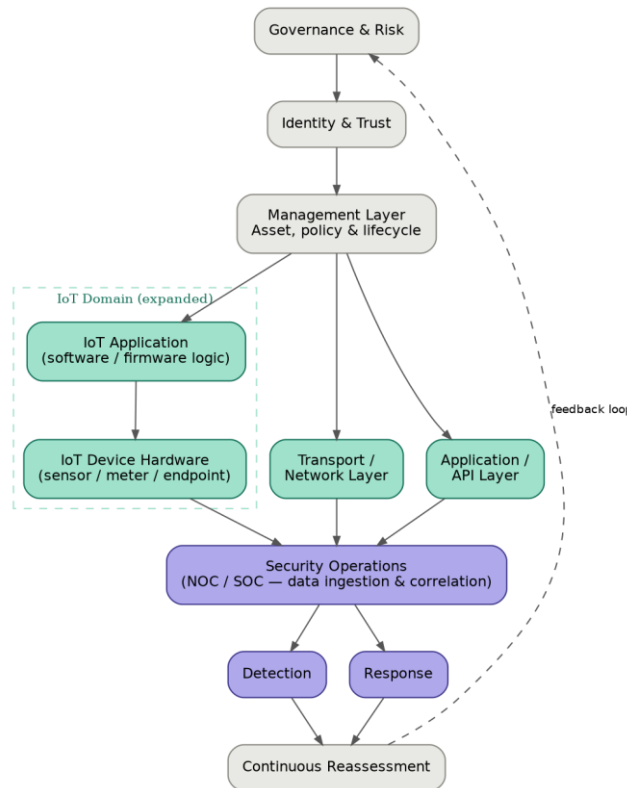
Converged Application-Transport-IoT Security Framework, version 2.5

A general-purpose way of securing where applications, networks, and connected devices meet.

What This Is

Applications, transport networks, and IoT devices usually get secured by three different teams working from three different playbooks. The gap between them, where an app hands data to the network, and the network hands it to a device, is where things tend to go wrong. CATIS is a six-function way of treating that seam as one continuously managed system instead of three separate ones. It sits on top of standards you likely already use, such as NIST CSF, IEC 62351, and ISO 27001, rather than replacing them, and it applies to any sector. The compliance rules you attach are the only thing that changes from one industry to the next.

How It's Structured



Governance sets the rules. Identity and Trust, along with the Management Layer, keep assets, policy, and credentials current. The three technical domains, IoT, Transport, and Application, get built and secured under those rules. Security Operations takes in and correlates what happens across all three, Detection and Response act on it, and Continuous Reassessment feeds lessons back to the top.

Where the Gaps Actually Are

This is a worked example, not a general claim: eight specific, documented limitations in two widely used standards, each matched to the CATIS function that answers it.

Standard	Documented gap	CATIS answer	Function
NISTIR 7628	Not updated since 2014; no DER/EV risk coverage	MAP requires an explicit DER/EV risk entry where these assets exist	MAP
NISTIR 7628	Authentication gaps persist even at full compliance	Certificate-based mutual authentication is a named minimum	SECURE
NISTIR 7628	Advisory only, no mandatory floor	A four-level maturity scorecard makes "aligned" checkable	Maturity Model

Standard	Documented gap	CATIS answer	Function
NISTIR 7628	Strategic-level only, no protocol specificity	AES-256 is named as the explicit encryption floor	SECURE
IEC 62351	Scoped to substations; distribution-edge IoT under-covered	MAP extends explicitly to smart meters and RTUs	MAP
IEC 62351	No unified certification body	VALIDATE tests the actual handshake outcome per device	VALIDATE
IEC 62351	About 20 fragmented parts, easy to cite the wrong one	The crosswalk names the exact part (8, 9, 10) per function	Crosswalk
IEC 62351	Commercial, an adoption barrier for smaller organizations	CATIS's own steps stay free as an accessible baseline	Whole framework

Standards Crosswalk

Function	NIST CSF 2.0	NIST 800-53 / 800-207	Sector reference
GOVERN	GOVERN	PM, PL	NISTIR 7628 Vol. 1
MAP	IDENTIFY	RA, CA	NISTIR 7628 Vol. 1
VALIDATE	IDENTIFY/PROTECT	CA, SA	IEC 62351 Part 1
SECURE	PROTECT	AC, SC, IA; SP 800-207	IEC 62351 Parts 8, 9
DETECT & RESPOND	DETECT/RESPOND	IR, SI	IEC 62351 Part 10
SUSTAIN	RECOVER	CP	NISTIR 7628 Vol. 3

Applying It to Your Sector

Sector	Example overlay
Health	EHR/telehealth plus connected medical devices; overlay with HIPAA, HHS 405(d), FDA 524B.
Power / Energy	Grid/SCADA plus smart meters and RTUs; overlay with NERC-CIP and IEC 62351.
Manufacturing / OT	MES/SCADA plus industrial sensors and PLCs; overlay with IEC 62443.
Financial Services	Banking platform plus ATMs and POS; overlay with PCI-DSS and FFIEC guidance.
General Enterprise IT	Any business software plus connected office systems; overlay with NIST CSF and ISO 27001 directly.

Glossary

Term	Meaning	Term	Meaning
AES	Advanced Encryption Standard	NERC-CIP	North America Electric Reliability Corp., Critical Infrastructure Protection
CATIS	Converged App-Transport-IoT Security	NIST	National Institute of Standards and Technology
CSF	Cybersecurity Framework (NIST)	NISTIR	NIST Interagency or Internal Report
DER	Distributed Energy Resource	NOC/SOC	Network / Security Operations Center
DLMS/COSEM	Smart-meter comms protocol and data model	OT	Operational Technology
EV	Electric Vehicle	PCI-DSS	Payment Card Industry Data Security Standard
FFIEC	Federal Financial Institutions Examination Council	PKI	Public Key Infrastructure

Term	Meaning	Term	Meaning
HHS	Department of Health and Human Services	PLC	Programmable Logic Controller
IEC	International Electrotechnical Commission	RBAC	Role-Based Access Control
IoT	Internet of Things	RTU	Remote Terminal Unit
ISO	International Organization for Standardization	SCADA	Supervisory Control and Data Acquisition
MES	Manufacturing Execution System	SP	Special Publication (NIST)